

CUADERNILLO DE ESTUDIO

CLASE 10

“Hacking ético y concientización”

10 Incluye actividad con Inteligencia Artificial

Profesor: Mg. Ing. Rodrigo Atilio Elgueta

Eje: Puente hacia la Unidad 4

Datos del/la estudiante

Nombre y apellido: _____

Grupo N.º: _____

Negocio Digital (TP): _____

Fecha: _____

Índice

1. ¿Qué es el hacking ético?	2
1.1. Los “sombreros” del hacking	2
2. Las fases del pentesting	3
3. OSINT: la inteligencia de fuentes abiertas	4
3.1. ¿Por qué le importa a un negocio digital?	4
3.2. Fuentes típicas de OSINT	4
4. Anatomía de un correo de phishing	6
5. El simulacro de phishing como herramienta	7
5.1. ¿Por qué es legítimo (y necesario)?	7
5.2. Métricas de un simulacro	7
6. Actividad con IA: Simulacro de phishing educativo	8
7. Parte 2: La campaña de concientización inversa	9
8. Puesta en común	10
9. Glosario de la Clase 10	11
10. Espacio para notas y hallazgos	11

1. ¿Qué es el hacking ético?

En la Clase 1 viviste una demo donde el docente accedió a la cámara de tu celular sin que lo notaras. Eso fue, en esencia, una **demostración controlada de hacking ético**: usar técnicas de ataque, pero con autorización, con un propósito educativo y sin causar daño.

Definición

El **hacking ético** (o pentesting) es la práctica de aplicar las mismas técnicas y herramientas que usaría un atacante malicioso, pero **con autorización explícita del dueño del sistema**, con el objetivo de encontrar vulnerabilidades **antes** de que sean explotadas y reportarlas para que se corrijan.

1.1 Los “sombreros” del hacking

En la cultura de la seguridad, se usa la metáfora de los sombreros para clasificar la intención y la legalidad:

Tipo	Descripción
White Hat (Sombrero blanco)	Hacker ético. Actúa con autorización, dentro de la ley, para proteger sistemas. Es un profesional contratado.
Black Hat (Sombrero negro)	Ciberdelincuente. Actúa sin autorización, viola la ley (Ley 26.388), busca beneficio propio o causar daño.
Gray Hat (Sombrero gris)	Zona intermedia. Puede encontrar vulnerabilidades sin autorización pero reportarlas (a veces a cambio de recompensa). Legalmente ambiguo.

La línea divisoria: el consentimiento

Las técnicas son **las mismas** para un white hat y un black hat. Lo único que los diferencia es el **consentimiento del dueño del sistema**. Un pentester que escanea una red sin autorización escrita está cometiendo un delito (acceso indebido, Ley 26.388), aunque su intención sea “ayudar”. **Siempre debe haber un acuerdo de alcance por escrito antes de empezar.**

2. Las fases del pentesting

Un test de penetración profesional no es “probar cosas al azar”. Sigue una metodología estructurada. Para un negocio digital, entender estas fases ayuda a saber qué esperar y qué valor obtener de una contratación de este tipo.

Fase	¿Qué se hace?	Valor para el negocio
1. Reconocimiento (OSINT)	Recolectar información pública del objetivo sin interactuar directamente.	Entender qué puede aprender un atacante solo con datos abiertos.
2. Escaneo y análisis	Identificar puertos, servicios, versiones y posibles puntos de entrada.	Mapear la superficie de ataque real.
3. Explotación	Intentar aprovechar las vulnerabilidades encontradas (de forma controlada).	Confirmar qué riesgos son reales y no solo teóricos.
4. Post-explotación	Ver hasta dónde se podría llegar si el ataque fuera exitoso.	Medir el impacto potencial real.
5. Reporte	Documentar hallazgos, evidencias y recomendaciones de remediación.	El entregable clave: el plan de acción para corregir.

Muchos negocios creen que el valor del pentesting es “encontrar agujeros”. En realidad, el valor está en el **reporte final**: un documento priorizado que le dice al negocio **qué arreglar primero, por qué y cómo**. Sin reporte accionable, el pentesting es solo ruido.

3. OSINT: la inteligencia de fuentes abiertas

Definición

OSINT (Open Source Intelligence) es la recolección y análisis de información proveniente de **fuentes públicas y abiertas**: redes sociales, sitios web, registros de dominios, ofertas de empleo, foros, etc. No requiere “hackear” nada: es información que la propia organización o sus empleados publican.

3.1 ¿Por qué le importa a un negocio digital?

Un atacante usa OSINT para preparar un **spear phishing** (Clase 3) o una campaña de ingeniería social. Cuanta más información pública haya, más fácil es construir un engaño creíble.

3.2 Fuentes típicas de OSINT

Fuente	¿Qué puede revelar?
LinkedIn	Nombres de empleados, cargos, jerarquías, tecnologías usadas, ex empleados (posible ingeniería social).
Sitio web corporativo	Estructura, sucursales, proveedores, correos de contacto (patrones de email).
WHOIS / registros de dominio	Datos del registrante, fechas, proveedores de hosting.
Ofertas de empleo	Stack tecnológico interno (“buscamos dev con experiencia en AWS y React”).
Redes sociales	Eventos, viajes de ejecutivos, fotos de oficinas (credenciales en post-its, pantallas).

Piensen en el negocio digital de su Trabajo Práctico Integrador (o en una empresa real conocida). Respondan:

1. ¿Qué tres datos podría obtener un atacante solo buscando en fuentes públicas?

2. ¿Cómo usaría esos datos para hacer creíble un correo de phishing dirigido a un empleado?

4. Anatomía de un correo de phishing

Antes de diseñar un simulacro, hay que conocer las **señales de alerta** (red flags) que un empleado debe aprender a reconocer. Estas son las piezas que después van a usar para su campaña de concientización.

Señal de alerta	¿Qué buscar?
Remitente sospechoso	El dominio no coincide con el oficial (ej. <code>banco-seguro.com</code> vs <code>banco-seguro-soporte.xyz</code>).
Sentido de urgencia	“Su cuenta será suspendida en 24 horas”, “Actúe ahora”. Busca que no pienses.
Saludo genérico	“Estimado cliente”, “Estimado usuario” en lugar de tu nombre real.
Enlaces sospechosos	Al pasar el mouse (sin hacer clic), la URL real no coincide con el texto del enlace.
Adjuntos inesperados	Archivos .zip, .exe, o documentos que piden “habilitar macros”.
Errores de redacción	Ortografía extraña, traducciones automáticas, formatos inconsistentes.
Solicitud de datos sensibles	Pedir contraseñas, tarjetas o códigos por correo (ninguna empresa sería lo hace).

5. El simulacro de phishing como herramienta

Definición

Un **simulacro de phishing** es una prueba controlada donde la propia organización (o un tercero autorizado) envía correos de phishing falsos a sus empleados para medir qué tan vulnerables son y, sobre todo, **para concientizarlos**.

5.1 ¿Por qué es legítimo (y necesario)?

El factor humano es el eslabón más débil (Clase 3). De nada sirve el mejor firewall si un empleado hace clic en un enlace malicioso. El simulacro convierte una amenaza abstracta en una **experiencia de aprendizaje concreta**.

5.2 Métricas de un simulacro

Métrica	¿Qué mide?
Tasa de apertura	¿Cuántos abrieron el correo?
Tasa de clic (CTR)	¿Cuántos hicieron clic en el enlace? (el indicador más importante)
Tasa de reporte	¿Cuántos reportaron el correo como sospechoso? (lo ideal: alta)
Tiempo de reporte	¿Cuánto tardó el primer empleado en alertar a TI?

El simulacro es para aprender, no para castigar

Un error grave es usar los resultados del simulacro para **sancionar** a los empleados que cayeron. Eso genera miedo y hace que nadie reporte incidentes reales. El objetivo es **capacitar**: quien cae en el simulacro recibe capacitación inmediata, no una sanción.

6. Actividad con IA: Simulacro de phishing educativo

Esta actividad involucra crear contenido de phishing. Por eso, las siguientes reglas son **innegociables**:

1. **Uso exclusivamente educativo:** el correo simulado nunca se usa fuera del aula ni con fines reales.
2. **Destinatario ficticio:** el “empleado” objetivo es un personaje inventado dentro del propio grupo. **NUNCA** se envía a una persona real.
3. **Sin envío real:** el correo se redacta y se analiza, pero **no se envía** por ningún medio a destinatarios externos al grupo.
4. **Supervisión docente:** todo el proceso se realiza bajo la mirada del profesor.

Parte 1: Generar el correo de phishing simulado con IA.

En grupos, usen una IA generativa para redactar un correo de phishing dirigido a un “empleado” ficticio de su negocio digital del TP. Pueden usar este prompt base:

“Actúa como un especialista en concientización de ciberseguridad. Redactá un correo de phishing simulado, exclusivamente con fines educativos, dirigido a un empleado ficticio de una [TIPO DE NEGOCIO]. El correo debe intentar que el empleado haga clic en un enlace falso. Incluye: remitente, asunto y cuerpo. No incluyas enlaces reales ni datos de personas reales.”

Remitente: _____

Asunto: _____

Cuerpo del correo:

7. Parte 2: La campaña de concientización inversa

Ahora viene el verdadero ejercicio de pensamiento crítico: **desarmar** el correo que generó la IA y convertirlo en una herramienta de capacitación.

Consigna: A partir del correo de phishing generado, diseñen la **campaña de concientización inversa**: ¿qué señales de alerta debería haber reconocido el “empleado”, y qué pieza de capacitación crearían para prevenir ese ataque?

1. Señales de alerta presentes en el correo generado (mínimo 3, usando la tabla de la Sección 4):

2. ¿Qué debería haber hecho el “empleado” al recibirlo? (paso a paso):

3. Pieza de capacitación propuesta: ¿qué formato usarían? (afiche, video corto, micro-learning, simulacro recurrente, etc.) y ¿cuál sería el mensaje central?

4. Auditoría de la IA: ¿el correo generado por la IA era realista? ¿Qué le faltó o qué le corregirían para que sea un buen material de entrenamiento?

8. Puesta en común

Cada grupo presenta al resto de la clase:

1. Las **señales de alerta** que detectó en su correo simulado.
2. La **pieza de concientización** que diseñó (o un boceto de ella).

Anoten las ideas más interesantes de los otros grupos que podrían aplicar a su propio TP Integrador:

Señales de alerta que destacaron otros grupos:

Ideas de campañas de concientización que les parecieron efectivas:

¿Qué aplicarían al programa de seguridad de su TP Integrador?

Conexión con el TP Integrador

La concientización es un **control humano** (Clase 6). Lo que diseñen hoy puede incorporarse a su TP Integrador como parte del plan de controles y de la Política de Seguridad Aceptable (Clase 11). Un programa de seguridad sin concientización está incompleto.

9. Glosario de la Clase 10

Término	Definición en una línea
Hacking ético	Uso autorizado de técnicas de ataque para encontrar y reportar vulnerabilidades.
Pentesting	Test de penetración; evaluación controlada de la seguridad de un sistema.
White Hat	Hacker ético que actúa con autorización y dentro de la ley.
Black Hat	Ciberdelincuente que actúa sin autorización.
OSINT	Inteligencia de fuentes abiertas (información pública).
Superficie de ataque	Conjunto de puntos por donde un atacante podría entrar.
Simulacro de phishing	Prueba controlada de phishing con fines de concientización.
Tasa de clic (CTR)	Porcentaje de destinatarios que hicieron clic en un enlace.
Concientización	Capacitación para que las personas reconozcan y eviten amenazas.
Ingeniería social	Manipulación psicológica para obtener información o acciones.

10. Espacio para notas y hallazgos

Anotá aquí las señales de phishing que más te sorprendieron, ideas para tu campaña de concientización, o dudas sobre el marco legal del hacking ético.